BTS SIO – OPTION SISR / SLAM – BLOC 3 – 1re ANNÉE

Protéger les données à caractère personnel

Thème 1 – Séances 1 et 2 (2 × 2 h)

Données personnelles • RGPD • Risques • Cartographie • Analyse de risques

Public	BTS SIO – option SISR / SLAM – Bloc 3 – 1re année
Durée	2 séances de 2 h (4 h)
Thème	Protéger les données à caractère personnel (séances 1 et 2)
Version	Support formateur – 21 octobre 2026
Auteur	TWAGIRUMUKIZA

Au programme

- **Séance 1** – Données personnelles et sensibles, principes et bases légales du RGPD, sûreté et sécurité, critères de sécurité, menaces ANSSI, impacts.
- **Séance 2** – Imprévu / aléa / risque, inventaire du SI, cartographie, criticité et matrice 5 × 5, défense en profondeur, plan de prévention.
- **Étude de cas FitZone** avec corrigé complet, quiz, fiches vierges, repères réglementaires, **sept schémas** (dont quatre en pleine page), **lexique** et **FAQ détaillée**.

Sommaire

Présentation du cours . . . 3

SÉANCE 1 – Données personnelles, principes du RGPD et risques . . . 4

1. Définitions . . . 4
2. Les principes fondamentaux du RGPD (art. 5) . . . 6
3. Typologie des risques . . . 6
4. Impacts : lien avec les sujets d'examen . . . 11

Synthèse de la séance 1 . . . 12

SÉANCE 2 – Analyse de risques et cartographie des données . . . 14

1. Qu'est-ce qu'un risque ? . . . 14
2. Connaître le système d'information et cartographier les données . . . 15
3. Prioriser les risques . . . 18
4. Stratégie de prévention et plan de prévention . . . 21
5. Étude de cas guidée : « FitZone » . . . 23

Synthèse de la séance 2 . . . 25

Annexes – Fiches vierges à imprimer . . . 26

Annexe A – Fiche de cartographie des traitements . . . 26
Annexe B – Tableau d'analyse de risques . . . 27
Annexe C – Plan de prévention . . . 28
Annexe D – Repères réglementaires . . . 29

Annexe E – Schémas de référence en pleine page . . . 30

Figure 1 – Types de menaces : périmètre de la sûreté et de la sécurité informatique . . . 30
Figure 2 – Principes de sécurité en informatique : confidentialité, disponibilité, intégrité et preuve . . . 31
Figure 3 – Les catégories d'impacts identifiées par l'ANSSI (méthode EBIOS) . . . 32
Figure 5 – Vulnérabilité, menace et risque . . . 33

Lexique . . . 34

FAQ détaillée . . . 37

A. RGPD et données personnelles . . . 37
B. Violations de données et sanctions . . . 38
C. Analyse de risques . . . 39
D. Méthode d'examen et lien avec le reste du programme . . . 40

Présentation du cours

Ce support couvre les **deux premières séances du Thème 1** du programme de 1re année du Bloc 3 (tronc commun SISR / SLAM) (« Protéger les données à caractère personnel »). Il articule le **cadre juridique** (RGPD) et la **démarche de gestion des risques** que le technicien SIO (SISR comme SLAM) devra savoir appliquer en entreprise et à l'examen.

	Séance 1 (2 h)	Séance 2 (2 h)
Thème	Données personnelles, principes du RGPD et risques	Analyse de risques et cartographie des données
Question directrice	*Qu'est-ce qu'on protège, et contre quoi ?*	*Comment évaluer, prioriser et traiter les risques ?*
Livrable	Mini-quiz et exercices de qualification	Dossier : cartographie, analyse de risques, plan de prévention
Évaluation	Quiz de synthèse	Cas FitZone noté sur 20

Compétences d'examen visées

- Qualifier une donnée (personnelle, sensible, non personnelle) et appliquer les **principes du RGPD**.
- Raisonner en **sûreté / sécurité** et en **critères de sécurité** (confidentialité, disponibilité, intégrité, preuve).
- Argumenter les **impacts** juridiques, financiers et réputationnels d'un incident.
- **Inventorier** un système d'information et **cartographier** les données.
- Conduire une **analyse de risques** (criticité = probabilité × gravité) et proposer un **plan de prévention**.
- **Analyser un document technique** simple (tableau de risques, fiche de cartographie, matrice).

> **Note formateur**
> **Fil rouge :** l'étude de cas **FitZone** (réseau de salles de sport) est présentée en séance 2 mais les exemples des deux séances y renvoient. Les corrigés sont regroupés en fin de chaque séance.
>
> **Matériel :** projecteur, impressions des annexes A à C (fiches vierges), calculatrice non requise.

SÉANCE 1 – Données personnelles, principes du RGPD et risques

Objectifs de la séance

- Qualifier une donnée : personnelle, sensible (art. 9) ou non personnelle.
- Citer et appliquer les **7 principes** du RGPD et les **6 bases légales**.
- Distinguer **sûreté et sécurité**, et raisonner avec les **4 critères** : confidentialité, disponibilité, intégrité, preuve.
- Classer un incident (type de violation, menace) et argumenter ses **impacts**.

Durée	Partie
10 min	Accroche : « Que savent Google, votre banque et votre lycée de vous ? »
25 min	1. Définitions : DCP, données sensibles, traitement, acteurs
30 min	2. Les principes fondamentaux du RGPD
5 min	Pause
30 min	3. Typologie des risques : sûreté/sécurité, 4 critères, menaces ANSSI
15 min	4. Impacts : juridiques, financiers, réputationnels
5 min	Synthèse et mini-quiz

1. Définitions

1.1 Donnée à caractère personnel (DCP) – art. 4 RGPD

Définition
Toute information se rapportant à une **personne physique identifiée ou identifiable**, directement ou indirectement.

- **Identification directe :** nom, prénom, photo, empreinte.
- **Identification indirecte :** numéro de sécurité sociale, e-mail nominatif, adresse IP, identifiant de cookie, plaque d'immatriculation, numéro de téléphone, ou le **recoupement** de plusieurs informations (ex. « femme, 42 ans, directrice de l'agence de Lyon »).

Une donnée n'est pas personnelle « par nature » : elle l'est **par sa capacité à identifier quelqu'un**. L'adresse `j.martin@entreprise.fr` est personnelle ; `contact@entreprise.fr` l'est beaucoup moins.

Exemples de DCP	Exemples de non DCP
Nom, e-mail professionnel nominatif, adresse IP, matricule employé	Statistiques réellement anonymisées
Géolocalisation d'un smartphone	Chiffre d'affaires de l'entreprise
Journaux de connexion associés à un compte	Données météorologiques

Point d'examen
Pseudonymisation (réversible avec une clé : ce sont **toujours des DCP**) ≠ **anonymisation** (irréversible : hors du champ du RGPD). Un identifiant haché reste une DCP.

1.2 Données sensibles – art. 9 (« catégories particulières »)

Leur traitement est **interdit par principe**, sauf exceptions (consentement explicite, obligations en droit du travail, intérêt vital, santé…).

Catégories de l'article 9	
Origine raciale ou ethnique	Données génétiques
Opinions politiques	Données biométriques (identification unique)
Convictions religieuses ou philosophiques	Données de santé
Appartenance syndicale	Vie sexuelle / orientation sexuelle

Attention

Les **condamnations pénales** (art. 10) et le **NIR** (numéro de sécurité sociale) ne figurent pas dans la liste de l'art. 9 mais bénéficient d'un **régime renforcé**. La localisation, les données financières et les données de mineurs appellent aussi une vigilance particulière.

Ne pas confondre : « donnée sensible » (RGPD, art. 9) et « information sensible » (valeur pour l'entreprise, vue en séance 2). Un arrêt maladie est une donnée sensible *au sens du RGPD* ; une grille tarifaire est une information sensible *pour l'entreprise*, sans être personnelle.

1.3 Vocabulaire indispensable

Terme	Définition
Traitement	Toute opération sur des données : collecte, enregistrement, consultation, stockage, transmission, **suppression**
Responsable de traitement (RT)	Celui qui détermine les **finalités et les moyens** du traitement
Sous-traitant	Traite les données **pour le compte** du RT (hébergeur, prestataire de paie…)
Personne concernée	La personne physique dont les données sont traitées
DPO / DPD	Délégué à la protection des données : conseille, contrôle, point de contact de la CNIL
CNIL	Autorité de contrôle française

Champ d'application : le RGPD s'applique à tout traitement de DCP de personnes situées dans l'UE, y compris par une entreprise hors UE qui cible ces personnes. Il est applicable depuis le **25 mai 2018**.

Mini-exercice de qualification

Qualifier : (a) l'adresse IP d'un visiteur ; (b) un arrêt maladie dans un dossier RH ; (c) la moyenne de ventes par magasin ; (d) l'empreinte digitale utilisée pour badger ; (e) l'identifiant haché d'un client. *(5 min, individuel)*

Corrigé : (a) DCP · (b) donnée sensible (santé) · (c) non DCP · (d) donnée sensible (biométrie) · (e) DCP (pseudonymisation).

2. Les principes fondamentaux du RGPD (art. 5)

#	Principe	Idée clé	Exemple concret
1	**Licéité, loyauté, transparence**	Base légale et information claire	Mention d'information à la collecte
2	**Limitation des finalités**	Finalité déterminée, explicite, légitime	Fichier client utilisé pour la livraison ≠ revente à un tiers
3	**Minimisation**	Seules les données **nécessaires**	Ne pas demander la date de naissance pour une newsletter
4	**Exactitude**	Données à jour, rectifiées	Procédure de mise à jour des coordonnées
5	**Limitation de la conservation**	Durée définie, puis suppression ou archivage	CV non retenus supprimés après une durée définie
6	**Intégrité et confidentialité**	Sécurité adaptée (art. 32)	Chiffrement, droits d'accès, sauvegardes
7	**Responsabilité (*accountability*)**	**Prouver** sa conformité	Registre, politiques, journaux, preuves

2.1 Les 6 bases légales (art. 6)

Tout traitement doit reposer sur **au moins une** base légale :

1. Consentement	2. Exécution d'un contrat	3. Obligation légale
4. Sauvegarde d'intérêts vitaux	5. Mission d'intérêt public	6. Intérêt légitime

Un consentement valable est **libre, spécifique, éclairé et univoque** (case non précochée) et **retirable** aussi facilement qu'il a été donné.

2.2 Lien avec la sécurité – art. 32 : le cœur du métier SISR

Le responsable de traitement et le sous-traitant mettent en œuvre des mesures techniques et organisationnelles **appropriées au risque** : pseudonymisation, chiffrement, capacité à garantir confidentialité, intégrité, disponibilité et résilience, capacité à rétablir l'accès aux données, tests et évaluations réguliers.

> **Point d'examen**
> Le RGPD n'impose pas « tel produit » : il impose une **démarche fondée sur le risque**. C'est exactement l'objet de la séance 2.

2.3 Protection dès la conception et par défaut – art. 25

- ***Privacy by design*** : intégrer la protection des données dès la conception d'un système.
- ***Privacy by default*** : par défaut, seules les données nécessaires sont traitées (ex. profil privé par défaut).

3. Typologie des risques

Le RGPD définit la **violation de données** (art. 4.12) comme une atteinte à la sécurité entraînant, de manière accidentelle ou illicite, la **destruction, la perte, l'altération, la divulgation ou l'accès non autorisé** à des DCP. Pour la comprendre, on distingue d'abord l'origine du risque, puis le critère de sécurité touché.

3.1 Sûreté et sécurité : deux familles de risques

	Sûreté	Sécurité
Protège contre	Dysfonctionnements et **accidents involontaires**	**Actions malveillantes volontaires**
Exemples de risque	Saturation d'un point d'accès, panne de disque, erreur d'exécution	Blocage d'un service, modification d'informations, vol d'information
Quantification	**Quantifiable statistiquement** (durée de vie moyenne d'un disque : X milliers d'heures)	Non quantifiable statistiquement, mais on peut **évaluer en amont** le niveau de risque et les impacts
Parades	Sauvegarde, dimensionnement, redondance des équipements	Contrôle d'accès, veille sécurité, correctifs, configuration renforcée, filtrage

Périmètre de la sûreté (menaces non intentionnelles, peu prévisibles) : accidents naturels (orage, inondation, incendie) ; menaces humaines (erreur, maladresse, négligence) ; menaces liées au matériel (mauvaise qualité).

> **Lien RGPD**
> Une violation de données peut venir d'un problème de **sûreté** (disque en panne sans sauvegarde, e-mail envoyé au mauvais destinataire) autant que de **sécurité** (ransomware). Le RGPD ne fait pas la différence : l'atteinte aux données suffit.

La sécurité, en cybersécurité, se concentre sur la protection des systèmes informatiques contre les **attaques malveillantes** : virus, logiciels espions, pirates informatiques. Les mesures de sécurité incluent l'utilisation de logiciels de sécurité, la mise en place de politiques de sécurité et la formation des utilisateurs. Elle consiste à prévenir les actes de malveillance en combinant les **moyens matériels, techniques, organisationnels et humains**.

La sûreté vise à prévenir les risques et les conséquences d'un **événement accidentel ou involontaire**. En cybersécurité, elle se concentre sur la **continuité des activités** et la récupération après une interruption, y compris après une cyberattaque : plans de reprise d'activité, sauvegarde des données, mesures pour minimiser les dommages.

> **En résumé**
> La **cybersécurité** englobe les deux aspects, sécurité et sûreté : protéger les systèmes et les données contre les menaces, et **assurer la continuité des activités** en cas d'attaque réussie.

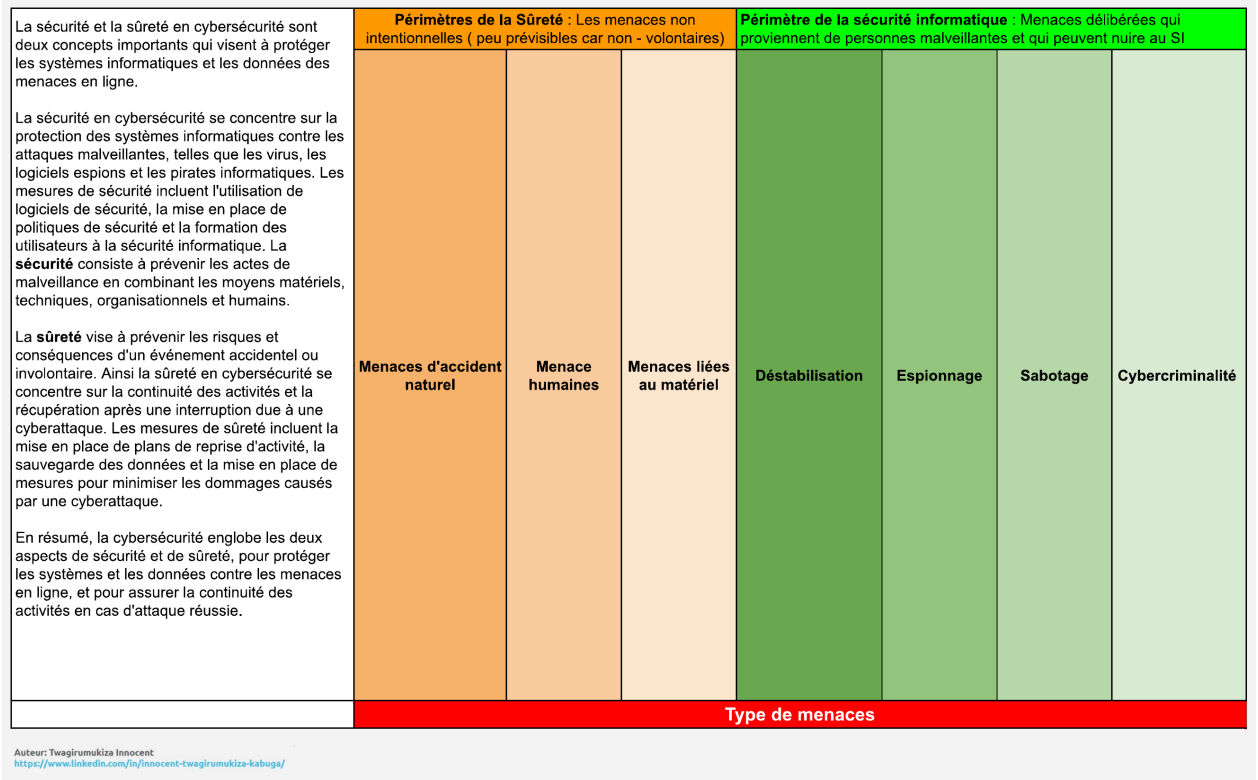


Figure 1 – Types de menaces : périmètre de la sûreté et de la sécurité informatique
Schéma : Twagirumukiza Innocent

À lire avec le § 3.4 : à gauche, les menaces non intentionnelles (sûreté) ; à droite, les quatre menaces délibérées de l'ANSSI (sécurité).

3.2 Les 4 critères de sécurité

Critère	Définition	Lien RGPD
Confidentialité	Seules les personnes autorisées ont accès aux données	Art. 5.1.f
Disponibilité	Les données sont accessibles rapidement et régulièrement	Art. 32.1.b et c
Intégrité	Assurance que les données consultées n'ont pas été modifiées	Art. 5.1.f
Preuve (non-répudiation)	Les accès aux données sont **conservés et exploitables**	Art. 5.2 (responsabilité) ; journalisation

La preuve consiste à apporter la preuve non réfutable d'un acte. Elle repose sur trois éléments :

Élément	Rôle	Exemple
Authentification	S'assurer de la légitimité de la demande d'accès et accorder les droits associés	Saisie d'un mot de passe, MFA
Imputabilité	Attribuer la responsabilité d'un acte à une personne **clairement identifiée**	Un compte = une personne (pas de compte partagé)
Traçabilité	Fournir un historique de l'utilisation de la donnée	Journaux d'accès, horodatage

> **À retenir**
> Ce critère sera réutilisé en séance 6 (chaîne de custody, hash des preuves) et en 2e année (journalisation, SIEM).

Définitions détaillées des critères (source : ANSSI) :

Critère	Ce que cela implique
Confidentialité	Les données et les informations doivent être protégées contre **tout accès non autorisé**. Il faut s'assurer qu'elles ne soient pas accessibles à des personnes non autorisées, comme les pirates informatiques ou les employés malveillants.
Disponibilité	Les données et les systèmes doivent être accessibles aux utilisateurs autorisés **en tout temps**. Il faut s'assurer que les systèmes ne soient pas rendus inaccessibles par des attaques de déni de service ou par des pannes de matériel.
Intégrité	Les données et les systèmes doivent être protégés contre **toute modification non autorisée**. Il faut s'assurer que les données ne soient pas altérées par des acteurs malveillants ou par des erreurs accidentelles.
Preuve (non-répudiation)	Apporter la **preuve non réfutable** d'un acte malveillant. Elle est assurée par la combinaison de trois éléments : authentification, imputabilité, traçabilité.

Les trois éléments de la preuve en détail :

Élément	Ce qu'il permet	Comment l'établir
Authentification	Vérifier l'identité d'une personne qui effectue une action sur un système informatique. **Elle permet de s'assurer de la légitimité de la demande d'accès et d'accorder les droits associés.**	Nom d'utilisateur et mot de passe, jetons d'authentification physiques, certificats numériques, authentification biométrique. L'**authentification forte** (méthodes robustes : certificats numériques, biométrie) prouve de manière fiable l'identité.
Imputabilité	Attribuer une action spécifique à une personne spécifique : essentiel pour établir la **responsabilité** en cas d'incident. Elle permet de prouver **qui** a effectué une action donnée.	Collecter des preuves fiables de l'identité de la personne et des informations sur l'action elle-même. Les **journaux d'audit** enregistrent les actions et les informations d'identification.
Traçabilité	Suivre les actions effectuées sur un système, **depuis leur origine jusqu'à leur destination finale** : transactions financières, communications électroniques, activités sur les réseaux d'entreprise.	Collecter des informations détaillées sur les actions et sur les personnes qui les ont effectuées (journaux d'audit). Résultat : l'**historique de l'utilisation** d'un système.

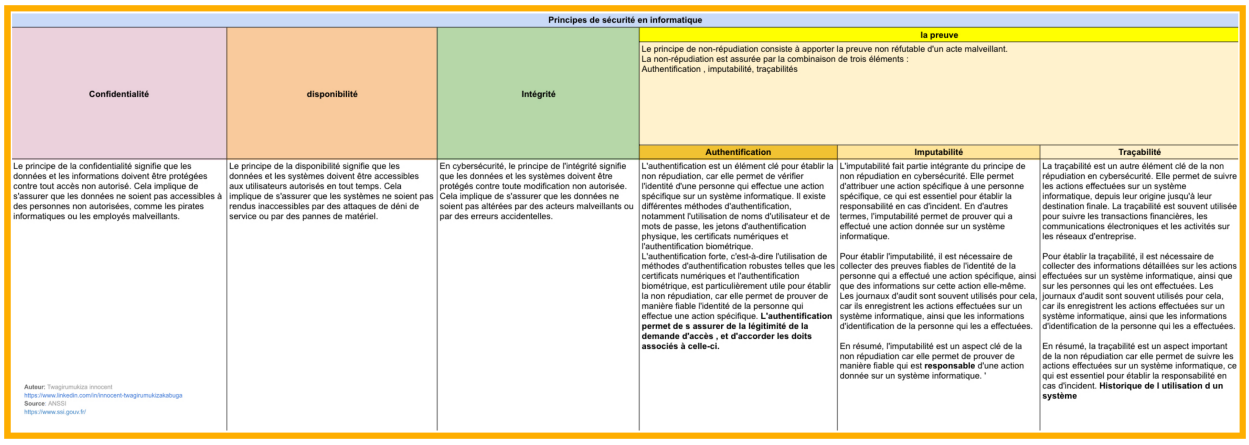


Figure 2 – Principes de sécurité en informatique : confidentialité, disponibilité, intégrité et preuve
Schéma : Twagirumukiza Innocent · Source : ANSSI

Version pleine page en annexe E. Source : ANSSI.

3.3 Types de violation selon le critère touché

Critère	Type de violation	Exemples	Conséquence pour la personne
Confidentialité	Fuite, accès non autorisé	Base clients exfiltrée ; e-mail au mauvais destinataire ; ordinateur volé non chiffré ; partage cloud public par erreur	Usurpation d'identité, hameçonnage ciblé, atteinte à la vie privée
Intégrité	Altération	Modification de notes, de dossiers médicaux ou de coordonnées bancaires, par un attaquant ou par erreur	Décisions erronées, fraude, préjudice
Disponibilité	Perte, indisponibilité	Ransomware, suppression accidentelle sans sauvegarde, panne prolongée	Impossibilité d'exercer ses droits, soins retardés

Origines possibles : externes malveillantes (phishing, ransomware, intrusion) · internes malveillantes (employé qui copie un fichier avant son départ) · internes accidentelles (erreur humaine, cause très fréquente) · techniques (panne, bug, mauvaise configuration) · environnementales (incendie, dégât des eaux).

Point d'examen

Piège classique : un ransomware qui chiffre sans exfiltrer est d'abord une atteinte à la **disponibilité** ; c'est aussi une atteinte à la **confidentialité** si les données ont été copiées, ce qui est fréquent avec la « double extorsion ». Toujours justifier.

3.4 Les menaces délibérées : la typologie de l'ANSSI

Quatre grands types de menaces sont mis en avant par l'ANSSI :

Menace	Types d'attaques
Déstabilisation	**Déni de service** : rendre un service inaccessible par une multitude de requêtes. **Défiguration** : remplacer des pages d'un site web pour diffuser un message idéologique. **Divulgation de données** : récupérer des données confidentielles en exploitant une vulnérabilité.
Espionnage	**Point d'eau** (*watering hole*) : infecter le site d'une organisation pour contaminer les ordinateurs des visiteurs. **Hameçonnage ciblé** (*spear phishing*) : usurper une personne connue du destinataire pour lui faire ouvrir une pièce jointe malveillante.
Sabotage	Modes d'attaque variés visant à créer une panne sur un périmètre ou sur l'ensemble du SI.
Cybercriminalité	**Rançongiciel** (*ransomware*) : données rendues inaccessibles jusqu'au paiement d'une rançon ; chantage possible à la publication. **Hameçonnage** (*phishing*) : tromper l'utilisateur pour obtenir des données personnelles, souvent bancaires (réseaux sociaux, courriel, SMS).

Exercice de classement

Classer chaque incident : **menace ANSSI** + **critère touché**. *(5 min)*

(a) Le site de la mairie est remplacé par un message politique. (b) Un faux e-mail « de la DRH » contient un avenant piégé. (c) La base RH est chiffrée contre rançon. (d) Un site de sous-traitant, consulté par vos salariés, a été piégé.

Corrigé : (a) déstabilisation (défiguration) / **intégrité** · (b) espionnage (spear phishing) ou cybercriminalité / **confidentialité** · (c) cybercriminalité (ransomware) / **disponibilité** (+ confidentialité si exfiltration) · (d) espionnage (point d'eau) / **confidentialité**.

4. Impacts : lien avec les sujets d'examen

4.1 Impacts juridiques

Sanction	Plafond / contenu
Amendes administratives (CNIL, art. 83) – niveau 1	Jusqu'à **10 M€ ou 2 % du CA mondial** : manquements aux obligations du RT ou du sous-traitant (dont la sécurité et la notification)
Amendes administratives – niveau 2	Jusqu'à **20 M€ ou 4 % du CA mondial** : principes de base, bases légales, droits des personnes. On retient le montant **le plus élevé**
Mesures correctrices	Mise en demeure, injonction, limitation ou interdiction du traitement, publicité de la sanction
Responsabilité civile	Droit à réparation du préjudice (art. 82)
Responsabilité pénale	Code pénal, art. 226-16 et suivants : jusqu'à **5 ans d'emprisonnement et 300 000 €** d'amende pour les personnes physiques
Obligation de notification	**72 h** à la CNIL après la prise de connaissance de la violation ; information des personnes si le risque est élevé (séance 5)

4.2 Impacts financiers

- Amendes, frais d'avocats, indemnisation des victimes.
- Coûts de remédiation : investigation, restauration, renforcement de la sécurité.
- Arrêt d'activité (perte de chiffre d'affaires), rançon éventuelle.
- Hausse des primes de cyberassurance, perte de contrats.

4.3 Impacts réputationnels

- Perte de confiance des clients, départ vers la concurrence.
- Médiatisation, impact sur la marque et sur le recrutement.
- Pour les collectivités et la santé : atteinte à la confiance du public.

4.4 Impacts sur les personnes (à ne pas oublier)

Le RGPD raisonne d'abord en **risque pour les droits et libertés des personnes** : usurpation d'identité, discrimination, perte financière, atteinte à la dignité, préjudice moral.

> **Pour illustrer**
> **Repères réels (sanctions CNIL publiques) :** Google LLC, 50 M€ (2019, transparence et consentement) ; Criteo, 40 M€ (2023). Elles montrent que les sanctions visent aussi les manquements aux **principes**, pas seulement les fuites.

4.5 Les six catégories d'impacts selon l'ANSSI (méthode EBIOS)

Les trois familles vues ci-dessus (juridique, financier, réputationnel) font partie d'une grille plus large : l'ANSSI identifie, dans sa méthode EBIOS, **six catégories d'impacts**. En séance 2, la **gravité** d'un risque s'évalue en examinant ces catégories.

Catégorie d'impact	Contenu
Missions et services de l'organisation	Conséquences directes ou indirectes sur la réalisation des missions et des services.
Humains, matériels ou environnementaux	**Sécurité ou santé des personnes** : conséquences sur l'intégrité physique des personnes. **Matériels** : dégâts matériels ou destruction de biens supports. **Environnement** : conséquences écologiques à court ou long terme.

Catégorie d'impact	Contenu
Gouvernance	**Capacité de développement ou de décision** : conséquences sur la liberté de décider, de diriger, de mettre en œuvre la stratégie de développement. **Lien social interne** : conséquences sur la qualité des liens sociaux au sein de l'organisation. **Patrimoine intellectuel ou culturel** : conséquences sur les connaissances non explicites accumulées par l'organisation, le savoir-faire, les capacités d'innovation, les références culturelles communes.
Financiers	Conséquences pécuniaires.
Juridiques	Conséquences suite à une non-conformité légale, réglementaire, normative ou contractuelle.
Image et confiance	Conséquences sur l'image de l'organisation, la notoriété, la confiance des clients.

Point d'examen

À l'examen, un énoncé peut demander d'« identifier les impacts » d'un incident : **balayer les six catégories** plutôt que se limiter aux amendes. Exemple FitZone, fuite de certificats médicaux : juridique (sanction CNIL), financier (indemnisations), image et confiance (abonnés qui partent), humain (atteinte à la vie privée et à la santé des personnes).

L'ANSSI, au travers de sa méthode EBIOS, identifie différentes catégories d'impacts.	
Impacts sur les missions et les services de l'organisation	Conséquences directes ou indirectes sur la réalisation des missions et services
Impacts humains, matériels conséquences sur l'intégrité physique de personnes. ou environnementaux	• Impacts sur la sécurité ou sur la santé des personnes : Impacts humains, matériels conséquences sur l'intégrité physique de personnes. ou environnementaux • Impacts matériels : dégâts matériels ou destruction de biens supports • Impacts sur l'environnement : conséquences écologiques à court ou long terme.
Impacts sur la gouvernance	• impacts sur la capacité de développement ou de décision : corse quences sur la liberté de décider, de diriger, de mettre en ceuvre la strattre de développement. Impacts sur la gouvernance • Impacts sur le lien social interne : conséquences sur la qualité des lier sociaux au sein de l'organisation. • Impacts sur le patrimoine intellectuel ou culturel : conséquences sur les connaissances non-explicites accumulées par l'organisation sur le savoir-fare. les capacités d'innovation, les références culturelles communes
Impacts financiers	Conséquences pécuniaires
Impacts juridiques	Conséquences suite à une non-conformité légale, réglementaire, normative ou contractuelle
Impacts sur l'image et la confiance	Conséquences sur l'image de l'organisation, la notoriété, la confiance des clients

Figure 3 – Les catégories d'impacts identifiées par l'ANSSI (méthode EBIOS)

Schéma : Twagirumukiza Innocent · Source : ANSSI, méthode EBIOS

Version pleine page en annexe E.

Synthèse de la séance 1

- DCP = information permettant d'identifier une personne, directement ou par recoupement. Données sensibles (art. 9) : interdites sauf exception.

- **7 principes** et **6 bases légales** ; l'article 32 impose des mesures **proportionnées au risque**.
- **Sûreté** = accidents ; **sécurité** = actions malveillantes. Les deux peuvent provoquer une violation de données.
- **4 critères** : confidentialité, disponibilité, intégrité, **preuve** (authentification + imputabilité + traçabilité).
- 4 menaces ANSSI : déstabilisation, espionnage, sabotage, cybercriminalité.
- Impacts : juridiques, financiers, réputationnels **et** pour les personnes.

Mini-quiz de fin de séance (type examen)

N°	Question	Corrigé
1	Une adresse IP est-elle une DCP ?	Oui : elle peut identifier indirectement une personne.
2	Un hash SHA-256 d'un e-mail est-il anonyme ?	Non : c'est de la pseudonymisation, donc toujours une DCP.
3	Quel principe est violé si l'on conserve indéfiniment les CV de candidats refusés ?	Limitation de la conservation.
4	Quel(s) critère(s) est (sont) atteint(s) quand un ransomware chiffre la base clients ?	Disponibilité ; et confidentialité en cas d'exfiltration.
5	Citez deux données sensibles.	Santé, biométrie, religion, appartenance syndicale, etc.
6	Plafond de l'amende la plus élevée du RGPD ?	20 M€ ou 4 % du CA mondial annuel (le plus élevé).
7	Un disque dur tombe en panne sans sauvegarde : sûreté ou sécurité ?	Sûreté. Mais c'est une violation de données au sens du RGPD (perte de disponibilité).
8	Quels sont les trois éléments de la preuve ?	Authentification, imputabilité, traçabilité.
9	Pourquoi un compte administrateur partagé pose-t-il problème ?	Pas d'imputabilité : on ne peut pas prouver qui a fait quoi.

SÉANCE 2 – Analyse de risques et cartographie des données

Objectifs de la séance

- Distinguer **imprévu, aléa, risque et problème** (norme NF X50-117).
- **Inventorier** un système d'information et **cartographier** les données d'une organisation.
- Conduire une analyse de risques simple : **criticité = probabilité × gravité**, matrice, seuil d'acceptabilité.
- Construire un **plan de prévention** (défense en profondeur, prévention et réparation, suivi).

Durée	Partie
5 min	Rappel de la séance 1
15 min	1. Notion de risque et démarche en 5 étapes
25 min	2. Connaître le SI et cartographier les données (inventaire, classification, réseaux)
20 min	3. Priorisation : criticité, matrice 5 × 5, zones, AMDEC
5 min	Pause
10 min	4. Stratégie de prévention : défense en profondeur, plan de prévention, suivi
35 min	5. Étude de cas FitZone (travail individuel) : parties A, B, C
5 min	Correction et synthèse

1. Qu'est-ce qu'un risque ?

1.1 Imprévu, aléa, risque, problème (norme NF X50-117)

Un risque est une situation problématique **qui n'existe pas encore** : avec le temps, il disparaît, ou il devient un problème à résoudre. La norme NF X50-117 (*management de projet – gestion du risque*) distingue quatre notions. Le test tient en deux questions :

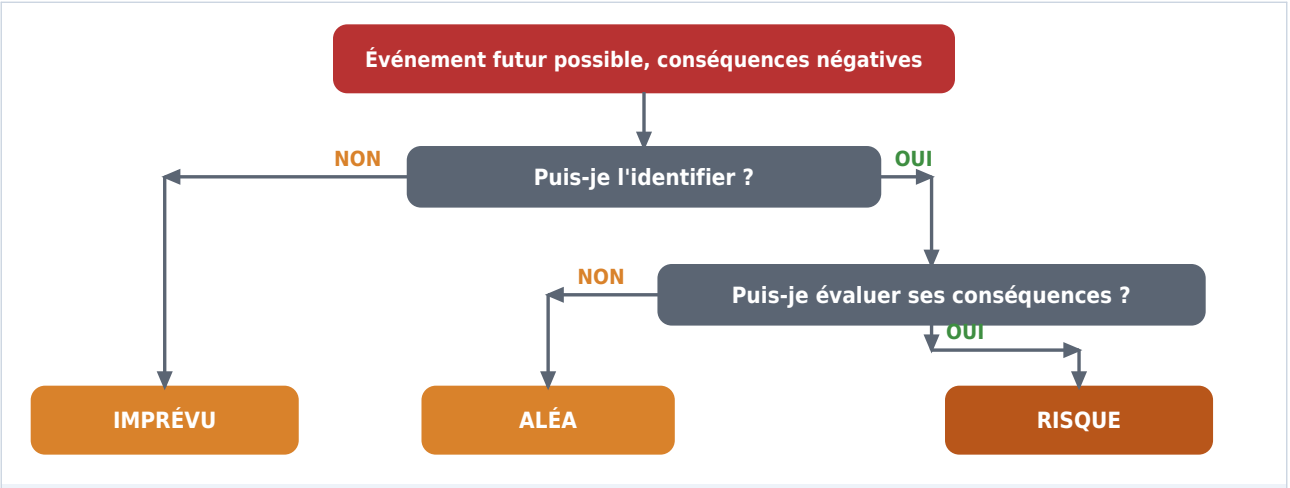


Figure 4 – Arbre de décision : imprévu, aléa, risque ou problème ?
Schéma : Twagirumukiza Innocent, d'après la norme NF X50-117

Notion	Définition	Exemple
Imprévu	Événement futur possible, **non identifiable**. Positif ou négatif. On ne peut pas le « prévoir », seulement y faire face	Une nouvelle réglementation en cours de projet
Aléa	Événement futur possible, identifiable, mais **non quantifiable** : impacts concrets impossibles à déterminer	Une faille encore inconnue d'un logiciel
Risque	Événement futur possible, identifiable et **quantifiable**	Ransomware sur le serveur de fichiers
Problème	Événement dommageable **déjà réalisé** : il faut le résoudre	Le serveur est chiffré

Attention

Un risque n'est pas une faute. Une faute est une **erreur non corrigée** : ne pas mettre à jour un outil après avoir été averti d'une faille de sécurité n'est plus un risque, c'est une faute (et déjà un problème).

1.2 La gestion des risques en 5 étapes

	Étape	Question à se poser
1	**Description du projet**	Qu'est-ce qu'on protège ? (SI, données, organisation)
2	**Identification des risques**	Que peut-il arriver ? (menaces, vulnérabilités)
3	**Priorisation**	Qu'est-ce qui est le plus critique ?
4	**Stratégie de prévention**	Que met-on en place ?
5	**Suivi des risques**	Où en est-on ? Qu'est-ce qui a changé ?

À retenir

Les étapes 1 et 2 s'appuient sur quatre sources : l'**environnement** du projet, l'**existant organisationnel**, l'**organisation** du projet et sa **description**.

2. Connaître le système d'information et cartographier les données

2.1 Pourquoi cartographier ?

On ne protège bien que ce que l'on connaît. La cartographie répond à : *quelles données ? où ? pour quoi faire ? qui y accède ? pour combien de temps ? avec quels prestataires ?* Elle alimente le **registre des traitements** (art. 30) et sert de base à l'analyse de risques. Tout projet de sécurité doit intégrer un **inventaire des biens**, qui permet de mieux déterminer les menaces et les mesures de protection applicables.

2.2 Identifier les composants du SI : du métier vers la technique

L'inventaire suit une **méthodologie logique** pour être exhaustif : on commence par les métiers, puis on descend vers les supports et les équipements.

Niveau	Contenu	Exemples
Actifs primordiaux	Processus métiers et données	Gestion des abonnements, paie, données de santé
Éléments supports	Applications, systèmes d'exploitation	Logiciel de gestion v4.2, Windows Server, Android
Équipements	Matériel	Smartphones, tablettes, commutateurs, routeurs/box, serveurs, ordinateurs

Identifiants utiles : adresse **MAC** (ordinateurs, serveurs, équipements réseau) ; **IMEI** (smartphones, tablettes ; composer *#06#).

Inventorier : que identifier et avec quels outils ?

À identifier	Détail
Les **données sensibles**	Mots de passe, cartes de crédit, documents personnels ; plan marketing, fichier client, brevets, contrats
Les **applications** et leur version	Office, navigateur web, logiciels métier…
Les **systèmes d'exploitation**	Android, iOS, Windows, Linux, macOS
Les **équipements**	Ordinateur, tablette, téléphone, serveur, box, routeur

- **Outils de découverte des machines du réseau :** ServiceNow, HP OpenView (aujourd'hui aussi GLPI, OCS Inventory ; *nmap* en séance Kali).
- **Outils de recensement des logiciels et versions installés :** Everest.

Lien RGPD
Les actifs primordiaux correspondent aux **traitements** du registre (art. 30) ; les éléments supports et les équipements correspondent aux **supports** de la fiche de cartographie ci-dessous.

2.3 Classifier l'information selon son degré d'importance

Catégorie	Définition	Part indicative
Stratégique	Information permettant de mettre à nu la valeur ajoutée de l'entreprise ou divulguant ses avantages compétitifs	≈ 5 %
Sensible	Ensemble de données qui, associées et mises en cohérence, peuvent révéler une partie de l'information stratégique	≈ 15 %
Divulgable (ouverte)	Données diffusables à l'extérieur sans préjudice pour l'entreprise	≈ 80 %

Attention
Ne pas confondre « information sensible » (valeur pour l'entreprise) et « donnée sensible » du RGPD (art. 9). Un dossier du personnel peut être *sensible pour l'entreprise* et contenir des *données personnelles* ; un arrêt maladie est une donnée sensible *au sens du RGPD*. Les deux classifications se croisent.

Exercice de classification
Compléter le tableau ci-dessous : cocher la catégorie et indiquer **qui est autorisé** à accéder à l'information. *(10 min)*

Information	Divulgable	Sensible	Stratégique	Accès autorisé pour
Contacts et dossiers du personnel				
Factures clients				
Factures fournisseurs				
Listes fournisseurs				
Données comptables				
Relevés de compte				
Propositions commerciales				
Contrats commerciaux				
Contrats de travail				
Données de production				
Grille tarifaire des produits				
Procédés de fabrication				
Veille concurrentielle				

2.4 Réseaux et points d'interconnexion

Sigle	Nom	Caractéristique
BAN	Body Area Network	Réseau de télétransmetteurs utilisé dans le domaine de la santé
PAN / WPAN	Personal Area Network (sans fil)	Centré sur une personne, moins de 10 m ; IrDA, ZigBee, Bluetooth, Wireless USB
LAN	Local Area Network	Réseau local interconnectant plusieurs périphériques et plusieurs individus
MAN	Metropolitan Area Network	Plus large qu'un LAN, étendu par exemple sur une ville
CAN	Campus Area Network	Plusieurs LAN, à la taille d'une université
WAN	Wide Area Network	Étendue nationale ou internationale (exemple : Internet)

Points d'interconnexion à connaître et à maîtriser :

- **Accès Internet** via une box (ADSL, fibre…) ou un téléphone / une carte 4G-5G.
- **Interconnexion avec d'autres réseaux** (partenaires, prestataires, universités) : liaison dédiée (E1/T1, fibre noire), **VPN** sur un WAN d'opérateur ou sur Internet, liaison satellite.

Lien RGPD
Chaque interconnexion est un **flux** à inscrire dans la cartographie : transfert à un sous-traitant, éventuellement hors UE.

2.5 La fiche de cartographie

Que recenser ? Pour chaque traitement :

Élément	Question à se poser
Traitement / finalité	À quoi servent les données ? (paie, CRM, vidéosurveillance…)
Catégories de données	Identité, coordonnées, bancaires, santé… Y a-t-il des données sensibles ?

Élément	Question à se poser
Personnes concernées	Clients, salariés, candidats, mineurs ?
Supports et lieux	Serveur interne, cloud, poste, papier, clé USB, mobile
Acteurs et accès	Qui y accède (services, sous-traitants) ?
Flux	D'où viennent-elles ? Où vont-elles ? Hors UE ?
Durée de conservation	Combien de temps ? Que se passe-t-il à l'issue ?
Mesures existantes	Chiffrement, sauvegarde, journalisation, droits

Modèle de fiche (exemple rempli) :

Traitement	Données	Sensibles ?	Personnes	Support	Accès	Durée	Sous-traitant
Gestion de la paie	Identité, RIB, NIR	NIR (régime renforcé)	Salariés	Serveur RH + SaaS paie	RH, compta	5 ans	Éditeur paie

Méthode en 4 étapes : (1) **lister** les traitements par service ; (2) **décrire** chacun avec le tableau ; (3) **représenter** les flux (source → système → destinataire) ; (4) **repérer** les points sensibles : données sensibles, transferts hors UE, accès excessifs, absence de durée de conservation.

3. Prioriser les risques

3.1 Vocabulaire de l'analyse de risques

Terme	Définition
Actif (bien)	Ce qu'il faut protéger (données, serveur, application)
Menace / source de risque	Ce qui peut causer un dommage (pirate, employé, panne)
Vulnérabilité	Faiblesse exploitable (mot de passe faible, absence de MFA, pas de sauvegarde)
Événement redouté	L'atteinte à un critère de sécurité qu'on veut éviter (fuite, altération, indisponibilité)
Criticité du risque	**Criticité (C) = Probabilité (P) × Gravité (G)**, évaluée **avant** et **après** les mesures (risque résiduel)

Démarche : identifier les biens à protéger → identifier les menaces → évaluer la **gravité** et la **probabilité d'occurrence** → calculer le **niveau de risque** → classer les risques et fixer un **seuil de prise en compte**. La hiérarchisation permet de déterminer les risques qui **doivent absolument être traités** et ceux qui sont **acceptables** (le système peut exister avec eux).

Vulnérabilité, menace et risque : trois notions à ne pas confondre

Notion	Définition
Vulnérabilité	Terme utilisé pour décrire les **faiblesses ou les points faibles** d'un système ou d'une infrastructure qui peuvent compromettre la sécurité.
Menace	Élément **intentionnel ou non intentionnel** qui pourrait causer des dommages à un système ou à une infrastructure, comme un virus informatique ou un pirate informatique.
Risque	**Probabilité qu'une menace exploite une vulnérabilité** pour causer des dommages. La gestion des risques consiste à identifier les vulnérabilités et les menaces, évaluer les risques potentiels et mettre en place des mesures pour les atténuer.

Vulnérabilité	Menace	Risque
Vulnérabilité est un terme utilisé pour décrire les faiblesses ou les points faibles d'un système ou d'une infrastructure qui peuvent compromettre la sécurité.	La menace est un élément intentionnel ou non-intentionnel qui pourrait causer des dommages à un système ou à une infrastructure, comme un virus informatique ou un pirate informatique.	le risque est la probabilité qu'une menace exploite une vulnérabilité pour causer des dommages. La gestion des risques en cybersécurité consiste à identifier les vulnérabilités et les menaces, évaluer les risques potentiels et mettre en place des mesures pour les atténuer.

Auteur: Twagirumukiza innocent
https://www.linkedin.com/in/innocent-twagirumukizakabuga

Figure 5 – Vulnérabilité, menace et risque
Schéma : Twagirumukiza Innocent

Version pleine page en annexe E.

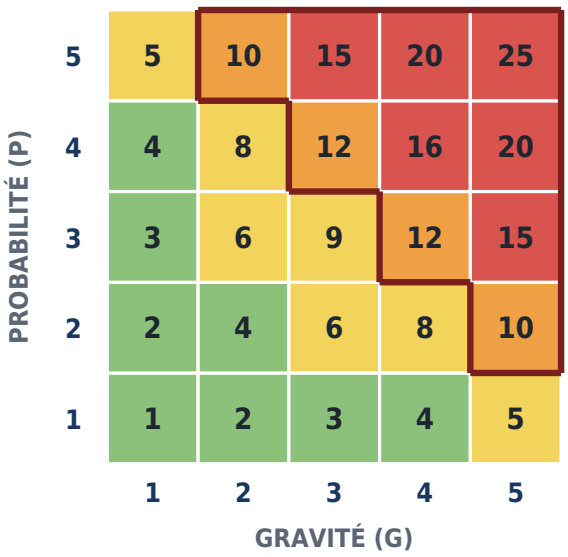
3.2 Échelles de cotation (1 à 5)

Niveau	Probabilité	Gravité
1	Très improbable	Négligeable
2	Peu probable	Limitée
3	Possible	Importante
4	Probable	Très importante
5	Quasi certaine	Critique / catastrophique

> **Variante à 4 niveaux**
> Dans le cadre RGPD / EBIOS, on utilise souvent **4 niveaux** (1 négligeable, 2 limité, 3 important, 4 maximal). Le principe est identique. **L'important est de rester cohérent** avec l'échelle donnée par l'énoncé.

3.3 La matrice de criticité 5 × 5

Le **produit** de la probabilité et de la gravité donne la **criticité** : plus elle est élevée, plus le risque doit retenir l'attention. Le contour rouge matérialise le **seuil d'acceptabilité** : au-delà (criticité ≥ 10), **des actions préventives sont obligatoires**.



1 – 4	Faible : acceptable
5 – 9	À surveiller : sous le seuil
10 – 14	À traiter : seuil atteint, action obligatoire
15 – 25	Prioritaire : traitement immédiat

Exemple : P = 4 et G = 3 → C = 12 → au-dessus du seuil : à traiter.

Principe de Pareto : 20 % des causes sont responsables de 80 % des effets. On concentre l'effort sur les risques de criticité la plus élevée.

Figure 6 – Matrice de criticité 5 × 5 (criticité = probabilité × gravité)
Schéma : Twagirumukiza Innocent

3.4 Les quatre « zones » de la matrice

Zone	Profil	Que faire ?
Risques perturbateurs	Très probables, gravité très faible	Ce sont des **problèmes à résoudre** : identifier les causes et les supprimer, sinon perturbations régulières qui parasitent le projet
Risques négligeables	Très peu probables, impact minimal	Ne pas en tenir compte
Risques de gravité	Dramatiques mais très peu probables (météorite, pandémie)	On « vit avec » : une parade n'est pas toujours possible
Risques intolérables	Très probables **et** extrêmement graves	Le projet n'est pas acceptable en l'état : réduire la criticité, **modifier** le projet pour faire disparaître le risque, ou le **refuser**

Attention
Nuance RGPD à bien faire passer : pour les données de santé ou biométriques, un risque de **forte gravité pour les personnes** (même peu probable) ne se « vit » pas : il impose des mesures renforcées et souvent une **analyse d'impact (AIPD, art. 35)**.

La règle « ne pas tenir compte des risques de gravité » vaut pour les risques de *projet*, pas pour les *droits et libertés des personnes*.

3.5 L'AMDEC (pour information)

L'AMDEC (analyse des modes de défaillance, de leurs effets et de leur criticité) ajoute un troisième facteur :

À retenir
Criticité = Fréquence × Gravité × Indéterminabilité

- **Fréquence** = probabilité ; **gravité** = impact potentiel.
- **Indéterminabilité** = probabilité de **ne pas détecter** l'incident qui transforme le risque en problème. Plus un incident est détectable rapidement, plus on peut limiter ses conséquences : c'est l'argument pour la **détection** (journaux, IDS, SIEM, vus en 2e année).

3.6 Traiter le risque : 4 options

Option	Principe	Exemple
Réduire	Mesures de sécurité (le plus fréquent)	MFA, sauvegarde hors ligne, chiffrement
Éviter	Supprimer le traitement ou l'activité à risque	Ne plus collecter l'empreinte digitale
Transférer	Assurance, sous-traitance encadrée par contrat	Cyberassurance, hébergeur certifié
Accepter	Risque résiduel assumé et **documenté**	Risque faible sous le seuil, validé par la direction

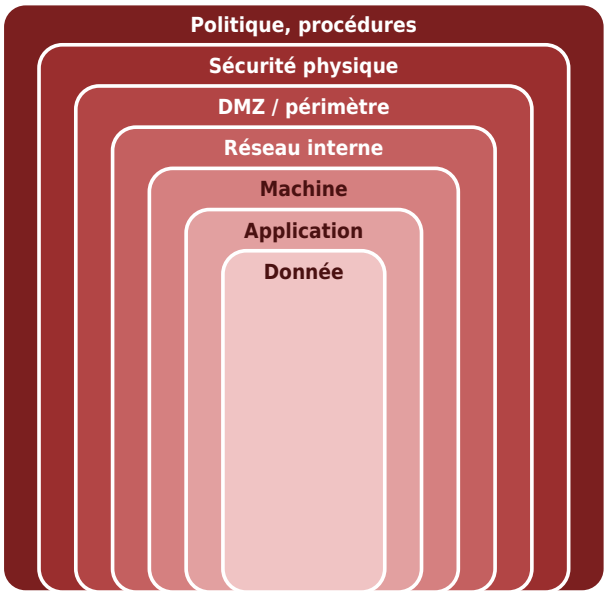
Pour **réduire** un risque, deux leviers (schéma « zone de risque acceptable ») : **limiter la probabilité** qu'il devienne un problème (prévention) et **réduire l'impact** s'il se réalise (protection, réparation).

4. Stratégie de prévention et plan de prévention

4.1 Une asymétrie entre attaquer et défendre

- L'attaque peut réussir en exploitant **une seule** vulnérabilité.
- La défense doit prendre en compte **l'ensemble** du système.

D'où le principe de **défense en profondeur** : plusieurs lignes de défense **indépendantes**, chacune constituant une barrière **autonome**, la perte de l'une impliquant de passer à un niveau de défense plus fort. Objectifs : **prévenir, bloquer, limiter, détecter, alerter, réagir, réparer**.



Couche	Mesures
Politique, procédures	Politique de sécurité, procédure de secours, sensibilisation
Sécurité physique	Gardiens, verrous, contrôle d'accès
DMZ / périmètre	Pare-feu, VPN, zone démilitarisée
Réseau interne	Sous-réseaux, NIDS, VLAN
Machine	Antivirus, correctifs de sécurité, HIDS, authentification
Application	Contrôle des entrées, test d'intrusion, communications chiffrées (HTTPS, SSH), traçabilité
Donnée	Chiffrement, mots de passe, droits d'accès par fichier/répertoire

Figure 7 – La défense en profondeur : sept couches de protection
Schéma : Twagirumukiza Innocent

> **À retenir**
> Ce schéma sera repris en 2e année pour la DMZ, les VLAN et le Zero Trust.

4.2 Le plan de prévention

Le plan de prévention est la **synthèse** de l'analyse de risques : un résumé exploitable des actions de **prévention** et de **réparation**, avec un **responsable** par risque. Il privilégie les actions pour les risques les plus importants.

Risque	P	G	C	Responsable	Prévention	Réparation	État
Risque A	4	4	16	Resp. SI	✔	✘	Orange
Risque B	3	3	9	DPO	✘	✔	Orange
Risque C	2	3	6	Resp. RH	✔	✔	Vert
Risque D	4	5	20	DSI	✘	✘	Rouge

Lecture : un risque sans prévention **ni** réparation (✘ ✘) est le plus dangereux. Le responsable suit le risque, vérifie que les actions sont réalisées et déclenche la réparation si le risque devient un problème.

4.3 Analyser un tableau de risques (type examen)

Format fréquent : **menace → vulnérabilité → actif et impact → risque → recommandation**.

Menace	Vulnérabilité	Actif et impact	Risque	Recommandation
Surchauffe de la salle serveurs (**élevée**)	Climatisation vieille de 10 ans (**élevée**)	Serveurs : tous les services indisponibles (**critique**) ; perte ≈ 45 000 € par occurrence	**Élevé**	Remplacer le climatiseur (≈ 2 700 €)
Attaque DDoS (**élevée**)	Pare-feu bien configuré, bonne atténuation (**faible**)	Site web indisponible (**critique**) ; ≈ 8 900 € par heure	**Moyen**	Surveiller le pare-feu
Inondation (**moyenne**)	Salle serveurs au 2e étage (**faible**)	Serveurs : services indisponibles (**critique**)	**Faible**	Aucune action
Suppression accidentelle de fichiers (**élevée**)	Droits corrects, audit, sauvegardes régulières (**faible**)	Partage de fichiers : données restaurables (**moyen**)	**Faible**	Surveiller les droits, les comptes privilégiés, les sauvegardes

Point d'examen

Lecture : le risque dépend de la **combinaison** menace × vulnérabilité × impact. Une menace élevée (DDoS) devient un risque moyen grâce à une faible vulnérabilité : **une mesure en place réduit le risque**. À l'inverse, une menace banale + une vulnérabilité élevée + un actif critique = risque élevé (climatisation).

Variante : tableau des scénarios de menace (vraisemblance sur 4 niveaux : 1 négligeable, 2 limité, 3 important, 4 maximal) :

Source de menace	Type	Bien support	Vraisemblance	Confidentialité	Disponibilité	Intégrité
Attaquant extérieur	Espionnage	Ordinateur de l'opérateur	**2 – limité** (données uniquement sur le serveur de base de données)	L'authentification n'est plus assurée aux seules personnes habilitées		

4.4 Suivre les risques

Les risques évoluent : leur criticité change, certains disparaissent, de nouveaux apparaissent (nouveaux acteurs, périmètre modifié, environnement qui change). Le suivi consiste à :

- revoir le plan de prévention à **chaque réunion d'étape** ou comité de pilotage ;
- à chaque modification significative, **réidentifier**, **recoter** et définir de nouvelles actions (reprise des étapes 2 à 4) ;
- utiliser le plan comme outil de **reporting et de pilotage**, qui révèle les phases critiques et se met à jour tout au long du projet.

> **Lien RGPD**
> C'est l'exigence des **art. 24 et 32** : réexaminer et actualiser les mesures, et pouvoir le **prouver** (responsabilité, art. 5.2).

5. Étude de cas guidée : « FitZone »

5.1 Contexte

FitZone est un réseau de **3 salles de sport** (45 salariés, environ 6 000 abonnés). Vous êtes technicien SISR chez le prestataire informatique. Le dirigeant vous demande « de voir où on en est avec le RGPD ». **Constats de votre visite :**

- Les abonnés sont gérés dans un **logiciel de gestion** hébergé sur un serveur dans l'arrière-boutique de la salle principale (fiches : identité, adresse, e-mail, téléphone, **IBAN** pour le prélèvement, **certificat médical** scanné, photo).
- L'accès aux salles se fait par **badge**, avec en option un **lecteur d'empreinte digitale** pour les abonnés « premium ».
- Les certificats médicaux sont stockés dans un dossier partagé `\\SRV\Abonnes`, **accessible à tous les salariés**.
- **Sauvegardes :** un disque USB branché en permanence sur le serveur.
- Une **newsletter** est envoyée via un outil en ligne ; la liste contient d'anciens abonnés partis il y a plus de 8 ans.
- Les coaches utilisent leur **smartphone personnel** et un groupe WhatsApp avec les noms et les objectifs de santé des abonnés.
- **Vidéosurveillance** à l'accueil et dans les vestiaires communs ; enregistrements conservés « jusqu'à saturation du disque ».
- Le **Wi-Fi** de l'accueil est partagé avec les postes de l'administration.
- Le mot de passe du compte administrateur du logiciel est `fitzone2019`, connu de tous.

5.2 Travail demandé (35 à 45 min, individuel)

Partie	Durée	Travail
A – Cartographie	10 min	Compléter la fiche ; inventaire en 3 niveaux ; classer 5 informations
B – Analyse de risques	15 min	5 événements redoutés (un par critère dont la preuve), menace ANSSI, P et G sur 5, C = P × G, matrice
C – Plan de prévention	10 min	Pour les 5 risques les plus critiques : mesure (couche), responsable, prévention, réparation, état

Chaque exercice est réalisé en solo. Livrable individuel : un document de 2 à 3 pages contenant la cartographie, l'analyse de risques (tableau coté + matrice) et le plan de prévention. Utiliser les fiches vierges des annexes A à C.

Critère d'évaluation	Points
Exhaustivité de la cartographie et de l'inventaire	4
Pertinence des événements redoutés, cotation justifiée, calcul exact de la criticité	6
Mesures adaptées, reliées aux principes RGPD et aux couches de défense	6
Clarté, professionnalisme, présentation en tableaux	4

5.3 Corrigé – Partie A : cartographie et inventaire

Traitement	Données	Sensibles ?	Support / accès	Problèmes relevés
Gestion des abonnements	Identité, coordonnées, IBAN, photo	Non (financières : vigilance)	Serveur local ; tous les salariés	Accès non limité ; compte admin partagé
Suivi d'aptitude médicale	Certificat médical	**Oui – santé**	Dossier partagé ouvert à tous	Base légale / consentement explicite à vérifier ; accès trop large ; **minimisation** (une attestation d'aptitude suffit souvent)
Contrôle d'accès biométrique	Empreinte digitale	**Oui – biométrie**	Lecteur + base	Régime strict ; proposer l'alternative badge ; AIPD probable
Newsletter	Nom, e-mail	Non	Outil en ligne (sous-traitant)	Conservation excessive (anciens abonnés) ; contrat sous-traitant ; consentement
Vidéosurveillance	Images	Non en soi	Disque local	Vestiaires : **disproportionné** ; durée non définie ; information par affichage
Communication des coaches	Noms, objectifs de santé	**Oui – santé**	WhatsApp, smartphones personnels	Hors contrôle de l'entreprise ; transfert possible hors UE

Niveau d'inventaire	FitZone
Actifs primordiaux	Gestion des abonnements, suivi d'aptitude médicale, contrôle d'accès biométrique, vidéosurveillance, newsletter
Éléments supports	Logiciel de gestion, outil de newsletter en ligne, WhatsApp, système du lecteur d'empreinte
Équipements	Serveur de l'arrière-boutique, disque USB, smartphones personnels des coaches, caméras, lecteur d'empreinte, Wi-Fi d'accueil

5.4 Corrigé – Partie B : analyse de risques (cotation sur 5)

Réf.	Événement redouté	Critère	Menace	Vulnérabilité	P	G	C	Niveau
R1	Fuite des certificats médicaux	Confidentialité	Cybercriminalité / erreur interne	Dossier ouvert à tous, pas de chiffrement	4	5	**20**	**Prioritaire**
R2	Ransomware chiffrant le serveur **et** la sauvegarde USB	Disponibilité (+ conf.)	Cybercriminalité	Sauvegarde connectée en permanence, mot de passe faible, Wi-Fi partagé	4	4	**16**	**Prioritaire**
R3	Diffusion d'images des vestiaires	Confidentialité	Malveillance interne	Visionnage libre, durée illimitée	3	4	**12**	**À traiter**
R4	Modification d'IBAN sans possibilité d'identifier l'auteur	Intégrité + **Preuve**	Fraude interne	Compte administrateur partagé, aucune journalisation	3	4	**12**	**À traiter**
R5	Fuite de la base d'empreintes digitales	Confidentialité	Espionnage / cybercriminalité	Données irremplaçables (non révocables)	2	5	**10**	**À traiter**
R6	Panne disque sans sauvegarde valide	Disponibilité	**Sûreté** (accident)	Aucun test de restauration	3	3	**9**	**À surveiller**

Point d'examen : distinguer risque, problème et faute
Le mot de passe partagé `fitzone2019` **n'est pas un risque : c'est une faute** (erreur non corrigée) et un **problème déjà réalisé**. Il se corrige immédiatement.
Le défaut de mise à jour du logiciel de gestion (P = 5, G = 2, C = 10) est un risque **perturbateur** : on supprime la cause plutôt que de l'« accepter ».

5.5 Corrigé – Partie C : plan de prévention (extrait)

Risque	C	Mesure (couche de défense)	Responsable	Prévention	Réparation	État
R1 Fuite certificats	20	Droits par groupe, chiffrement, ne conserver qu'une attestation d'aptitude (Donnée) – *minimisation*	Direction + prestataire SISR	✘ à faire	✘ procédure de notification 72 h	Rouge
R2 Ransomware	16	Sauvegarde **3-2-1** avec copie hors ligne ou immuable, test de restauration, MFA, Wi-Fi séparé (Réseau, Machine)	Prestataire SISR	✘ à faire	✘ plan de restauration	Rouge
R3 Vestiaires	12	Retirer les caméras des vestiaires, fixer une durée de conservation, afficher l'information (Politique)	Direction	✘ à faire	–	Orange
R4 Modification d'IBAN	12	Comptes nominatifs, mots de passe robustes, journalisation (Application, **Preuve**)	Direction	✘ à faire	✔ si les logs sont exploitables	Orange
R5 Empreintes	10	Alternative badge, base légale (consentement explicite), **AIPD**, chiffrement des gabarits	DPO / référent RGPD	✘ à faire	✘	Orange

Autres mesures (gouvernance) : supprimer les contacts inactifs et définir des durées de conservation (art. 5.1.e) ; cesser les échanges de données de santé sur WhatsApp personnel, utiliser un outil validé et une charte d'usage ; tenir un **registre des traitements** ; désigner un référent RGPD ; encadrer les sous-traitants par contrat ; sensibiliser le personnel.

Synthèse de la séance 2

- **Imprévu, aléa, risque, problème** : un risque est identifiable **et** quantifiable ; une faute est une erreur non corrigée.
- 5 étapes : description, identification, priorisation, prévention, suivi.
- Inventaire du SI : **métiers et données → applications / OS → équipements**. Cartographier = connaître avant de protéger (base du registre, art. 30).
- **Criticité = P × G** ; au-dessus du seuil (≥ 10 sur la matrice 5 × 5), action obligatoire.
- Quatre zones : perturbateurs, négligeables, de gravité, intolérables.
- **Défense en profondeur** ; plan de prévention = prévention + réparation + responsable, **mis à jour** en continu.
- Risque élevé pour les personnes → **AIPD** (art. 35).

Conseils pour l'épreuve

- Citer l'**article ou le principe** du RGPD concerné.
- Raisonner en **critères de sécurité** (C, D, I, preuve) et en **impact pour les personnes**.
- Toujours **justifier** : événement redouté → vulnérabilité → mesure.
- Ne pas lister des outils : proposer des **mesures proportionnées et justifiées**, techniques **et** organisationnelles.
- Présenter les réponses sous forme de **tableaux** : lisible et valorisé.

Annexes – Fiches vierges à imprimer

Annexe A – Fiche de cartographie des traitements

Traitement / finalité	Données	Sensibles ?	Personnes	Support	Accès	Durée	Sous-traitant

Annexe B – Tableau d'analyse de risques

Réf.	Événement redouté	Critère	Menace	Vulnérabilité	P	G	C = P×G	Niveau

Annexe C – Plan de prévention

Risque	C	Mesure(s) et couche de défense	Responsable	Prévention ✓/✗	Réparation ✓/✗	État

Annexe D – Repères réglementaires

Article RGPD	Objet	Utilisé dans
4	Définitions (DCP, traitement, violation de données)	Séance 1, § 1 et 3
5	Principes (licéité, finalités, minimisation, exactitude, conservation, intégrité/confidentialité, responsabilité)	Séance 1, § 2
6	Bases légales du traitement	Séance 1, § 2.1
9 et 10	Catégories particulières de données ; condamnations pénales	Séance 1, § 1.2
24	Responsabilité du responsable de traitement (réexamen des mesures)	Séance 2, § 4.4
25	Protection dès la conception et par défaut	Séance 1, § 2.3
30	Registre des activités de traitement	Séance 2, § 2.1 et 2.5
32	Sécurité du traitement (mesures adaptées au risque)	Séances 1 et 2
33 et 34	Notification à la CNIL (72 h) et aux personnes	Séance 5 du thème
35	Analyse d'impact relative à la protection des données (AIPD)	Séance 2, § 3.4 et FitZone
82 et 83	Droit à réparation ; amendes administratives	Séance 1, § 4

Annexe E – Schémas de référence en pleine page

Ces schémas sont présentés ici en grand format pour la lecture et la projection. La numérotation est celle des figures du cours (les figures 4, 6 et 7 sont des schémas vectoriels déjà lisibles dans le texte). Tous les schémas sont aussi agrandissables et téléchargeables sur le site du cours.

Figure 1 – Types de menaces : périmètre de la sûreté et de la sécurité informatique

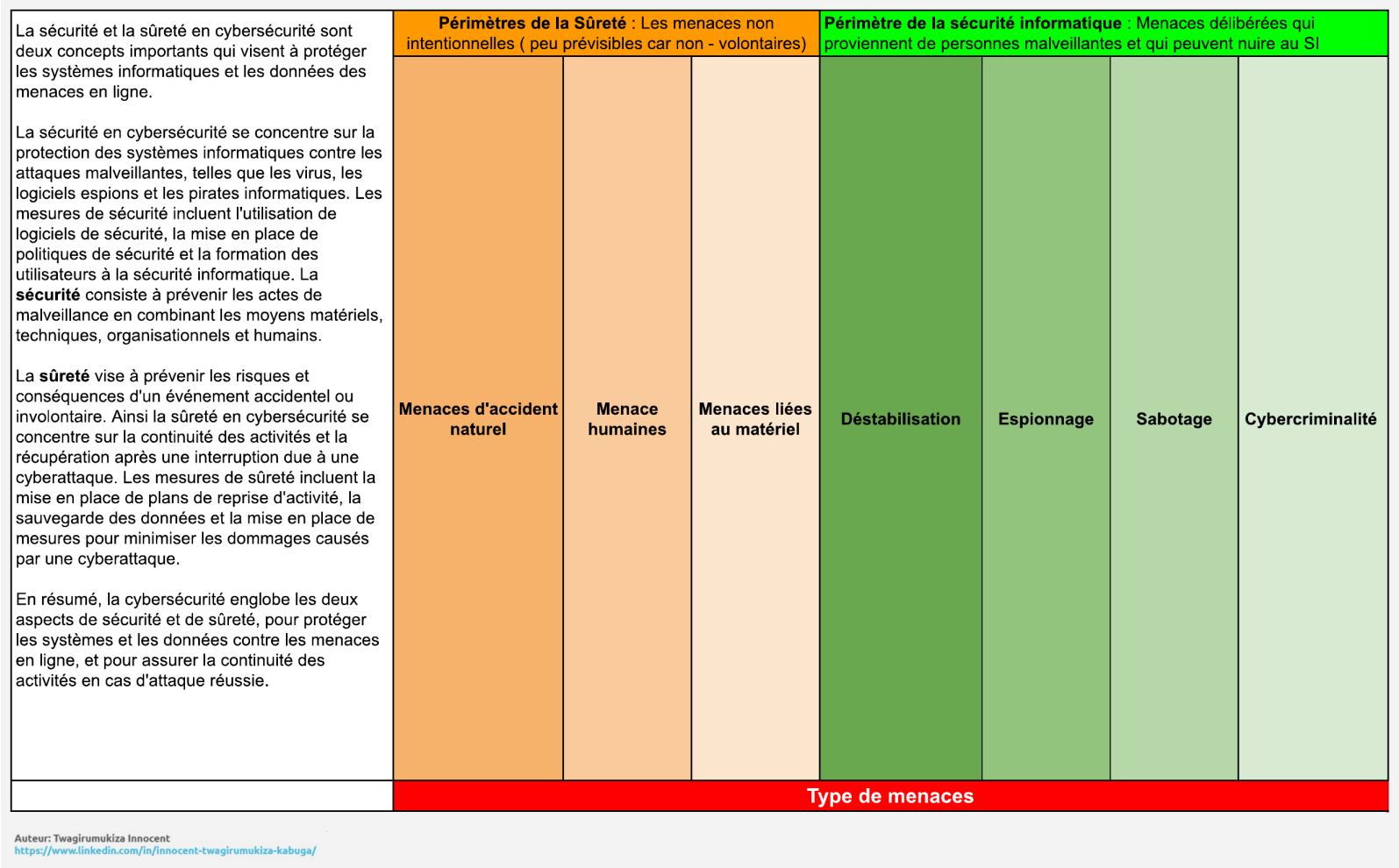


Schéma : Twagirumukiza Innocent

Figure 2 – Principes de sécurité en informatique : confidentialité, disponibilité, intégrité et preuve

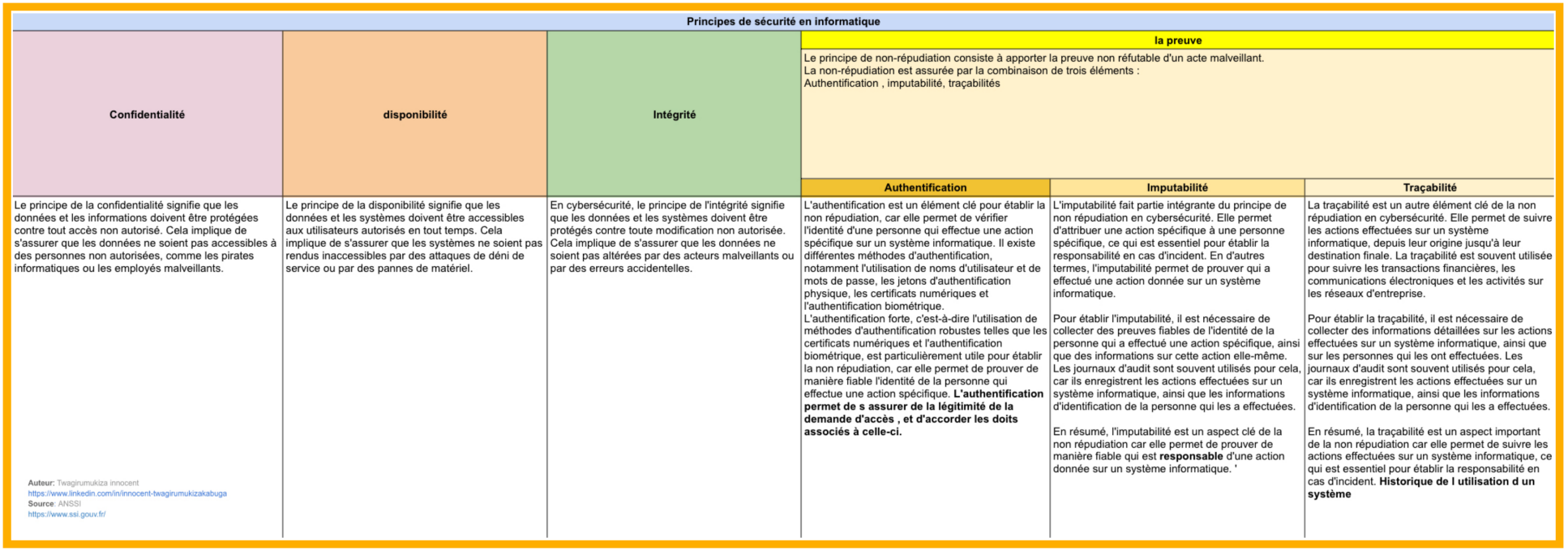


Schéma : Twagirumukiza Innocent · Source : ANSSI

Figure 3 – Les catégories d'impacts identifiées par l'ANSSI (méthode EBIOS)

L'ANSSI, au travers de sa méthode EBIOS, identifie différentes catégories d'impacts.	
Impacts sur les missions et les services de l'organisation	Conséquences directes ou indirectes sur la réalisation des missions et services
Impacts humains, matériels conséquences sur l'intégrité physique de personnes. ou environnementaux	• Impacts sur la sécurité ou sur la santé des personnes : Impacts humains, matériels conséquences sur l'intégrité physique de personnes. ou environnementaux • Impacts matériels : dégâts matériels ou destruction de biens supports • Impacts sur l'environnement : conséquences écologiques à court ou long terme.
Impacts sur la gouvernance	• impacts sur la capacité de développement ou de décision : corse quences sur la liberté de décider, de diriger, de mettre en ceuvre la strattre de développement. Impacts sur la gouvernance • Impacts sur le lien social interne : conséquences sur la qualité des lier sociaux au sein de l'organisation. • Impacts sur le patrimoine intellectuel ou culturel : conséquences sur les connaissances non-explicites accumulées par l'organisation sur le savoir-fare. les capacités d'innovation, les références culturelles communes
Impacts financiers	Conséquences pécuniaires
Impacts juridiques	Conséquences suite à une non-conformité légale, réglementaire, normative ou contractuelle
Impacts sur l'image et la confiance	Conséquences sur l'image de l'organisation, la notoriété, la confiance des clients

Schéma : Twagirumukiza Innocent · Source : ANSSI, méthode EBIOS

Figure 5 – Vulnérabilité, menace et risque

Vulnérabilité	Menace	Risque
Vulnérabilité est un terme utilisé pour décrire les faiblesses ou les points faibles d'un système ou d'une infrastructure qui peuvent compromettre la sécurité.	La menace est un élément intentionnel ou non-intentionnel qui pourrait causer des dommages à un système ou à une infrastructure, comme un virus informatique ou un pirate informatique.	le risque est la probabilité qu'une menace exploite une vulnérabilité pour causer des dommages. La gestion des risques en cybersécurité consiste à identifier les vulnérabilités et les menaces, évaluer les risques potentiels et mettre en place des mesures pour les atténuer.

Auteur: Twagirumukiza innocent
https://www.linkedin.com/in/innocent-twagirumukizakabuga

Schéma : Twagirumukiza Innocent

Lexique

Les termes sont classés par ordre alphabétique. La colonne « Réf. » renvoie à la séance où la notion est introduite (S1 ou S2).

Terme	Définition	Réf.
Actif (bien)	Ce qu'il faut protéger : données, processus métiers, applications, équipements.	S2
AIPD (DPIA)	Analyse d'impact relative à la protection des données (art. 35). Obligatoire quand un traitement présente un **risque élevé** pour les droits et libertés des personnes (biométrie, santé à grande échelle, surveillance…).	S2
Aléa	Événement futur possible, identifiable mais **non quantifiable** (NF X50-117).	S2
AMDEC	Analyse des modes de défaillance, de leurs effets et de leur criticité. Criticité = fréquence × gravité × indéterminabilité.	S2
Anonymisation	Processus **irréversible** rendant impossible l'identification d'une personne. Les données anonymisées sortent du champ du RGPD.	S1
ANSSI	Agence nationale de la sécurité des systèmes d'information. Elle publie la typologie des 4 menaces : déstabilisation, espionnage, sabotage, cybercriminalité.	S1
Authentification	Vérification de la légitimité d'une demande d'accès (mot de passe, MFA, certificat). Un des trois éléments de la preuve.	S1
Authentification forte	Authentification reposant sur des méthodes robustes (certificats numériques, biométrie, jetons physiques) qui prouvent de manière fiable l'identité de la personne.	S1
BAN / PAN / LAN / MAN / CAN / WAN	Types de réseaux selon leur étendue : corps, personne, local, métropolitain, campus, étendu (Internet).	S2
Base légale	Fondement juridique d'un traitement (art. 6) : consentement, contrat, obligation légale, intérêts vitaux, mission d'intérêt public, intérêt légitime.	S1
Cartographie des données	Recensement des traitements, des données, des supports, des accès, des flux et des durées de conservation. Base du registre (art. 30).	S2
Catégories d'impacts (ANSSI / EBIOS)	Six catégories : missions et services ; humains, matériels et environnementaux ; gouvernance ; financiers ; juridiques ; image et confiance.	S1
Chaîne de custody	Suivi documenté de la conservation d'une preuve numérique (qui, quand, comment), avec empreintes (hash). Vue en séance 6 du thème.	S1
CNIL	Commission nationale de l'informatique et des libertés : autorité de contrôle française du RGPD.	S1
Confidentialité	Seules les personnes autorisées ont accès aux données. Critère de sécurité.	S1
Consentement	Manifestation de volonté **libre, spécifique, éclairée et univoque**, retirable à tout moment.	S1
Criticité (C)	Niveau d'un risque : **C = Probabilité (P) × Gravité (G)**. Comparée à un seuil d'acceptabilité.	S2
Cybercriminalité	Menace ANSSI regroupant notamment le rançongiciel et l'hameçonnage.	S1
DCP	Donnée à caractère personnel : toute information se rapportant à une personne physique identifiée ou identifiable (art. 4).	S1
Défense en profondeur	Plusieurs lignes de défense **indépendantes** et autonomes ; la perte d'une ligne conduit à un niveau de défense plus fort.	S2
Déni de service (DoS / DDoS)	Attaque saturant un service par une multitude de requêtes pour le rendre indisponible. DDoS : depuis de nombreuses sources.	S1
Disponibilité	Les données sont accessibles rapidement et régulièrement. Critère de sécurité.	S1

Terme	Définition	Réf.
DMZ	Zone démilitarisée : segment réseau intermédiaire entre Internet et le réseau interne, où l'on place les services exposés. Approfondie en 2e année.	S2
Données sensibles	Catégories particulières (art. 9) : santé, biométrie, génétique, origine, opinions politiques, religion, syndicat, vie sexuelle. Traitement interdit sauf exception.	S1
Double extorsion	Ransomware qui chiffre **et** exfiltre les données, avec menace de publication.	S1
DPO / DPD	Délégué à la protection des données : conseille, contrôle la conformité, point de contact de la CNIL et des personnes.	S1
EBIOS RM	Méthode d'analyse de risques de l'ANSSI (ateliers, gravité, vraisemblance, scénarios). Approfondie en 2e année.	S2
Événement redouté	Atteinte à un critère de sécurité qu'on cherche à éviter (fuite, altération, indisponibilité, absence de preuve).	S2
Faute	Erreur **non corrigée** (ex. ne pas appliquer un correctif après une alerte). Ce n'est plus un risque.	S2
Gravité (G)	Ampleur des conséquences si le risque se réalise.	S2
Hameçonnage (phishing)	Tromper un utilisateur pour obtenir des données personnelles ou bancaires (courriel, SMS, réseaux sociaux). Variante ciblée : *spear phishing*.	S1
Imprévu	Événement futur possible, **non identifiable**. Positif ou négatif.	S2
Imputabilité	Possibilité d'attribuer un acte à une personne clairement identifiée (un compte = une personne).	S1
Information divulgable / sensible / stratégique	Classification de l'information selon sa valeur pour l'entreprise (≈ 80 % / 15 % / 5 %). À ne pas confondre avec les « données sensibles » du RGPD.	S2
Intégrité	Assurance que les données consultées n'ont pas été modifiées. Critère de sécurité.	S1
Journal d'audit	Enregistrement des actions effectuées sur un système et des informations d'identification de leur auteur. Il fonde l'imputabilité et la traçabilité.	S1
Menace	Source potentielle de dommage : pirate, employé, panne, sinistre.	S2
Minimisation	Ne collecter que les données **nécessaires** à la finalité (art. 5.1.c).	S1
NIR	Numéro d'inscription au répertoire (sécurité sociale). Régime de protection renforcé.	S1
Non-répudiation (preuve)	Impossibilité pour l'auteur d'un acte de le nier : authentification + imputabilité + traçabilité.	S1
Notification de violation	Information de la CNIL sous **72 h** (art. 33) et, si le risque est élevé, des personnes concernées (art. 34).	S1
Plan de prévention	Synthèse de l'analyse de risques : actions de prévention et de réparation, responsable, suivi.	S2
Privacy by design / by default	Protection des données dès la conception / par défaut (art. 25).	S1
Probabilité (P)	Chance qu'un risque devienne un problème (aussi appelée vraisemblance ou fréquence).	S2
Problème	Événement dommageable **déjà réalisé**, à résoudre.	S2
Pseudonymisation	Remplacement d'identifiants par un pseudonyme ; **réversible** avec une clé, donc toujours des DCP.	S1
Ransomware (rançongiciel)	Logiciel qui rend les données inaccessibles (chiffrement) jusqu'au paiement d'une rançon.	S1
Registre des traitements	Document recensant les traitements de DCP (art. 30) : finalités, catégories de données, destinataires, durées, mesures.	S2

Terme	Définition	Réf.
Responsable de traitement (RT)	Organisme qui détermine les **finalités et les moyens** du traitement.	S1
Risque	Événement futur possible, identifiable et **quantifiable**. Peut disparaître ou devenir un problème.	S2
Risque résiduel	Risque restant après application des mesures de sécurité ; il doit être accepté et documenté.	S2
Sabotage	Menace ANSSI visant à provoquer une panne sur un périmètre ou sur l'ensemble du SI.	S1
Sécurité	Protection contre les **actions malveillantes volontaires**.	S1
Seuil d'acceptabilité	Niveau de criticité à partir duquel des actions préventives sont obligatoires (ici ≥ 10 sur 25).	S2
Sous-traitant	Traite des données pour le compte du RT ; encadré par un contrat (art. 28).	S1
Sûreté	Protection contre les dysfonctionnements et les **accidents involontaires**.	S1
Traitement	Toute opération sur des données : collecte, stockage, consultation, transmission, suppression…	S1
Traçabilité	Historique de l'utilisation d'une donnée (journaux d'accès, horodatage).	S1
Violation de données	Atteinte à la sécurité entraînant destruction, perte, altération, divulgation ou accès non autorisé à des DCP (art. 4.12).	S1
VPN	Réseau privé virtuel : tunnel chiffré sur un réseau d'opérateur ou sur Internet.	S2
Vulnérabilité	Faiblesse exploitable : mot de passe faible, absence de MFA, correctif manquant, pas de sauvegarde.	S2
Watering hole (point d'eau)	Infection du site d'une organisation pour contaminer les ordinateurs de ses visiteurs.	S1

FAQ détaillée

Les questions que posent le plus souvent les étudiants (et les jurys), regroupées par thème. Les réponses sont volontairement développées pour servir de support de révision.

A. RGPD et données personnelles

Q1. Une adresse IP est-elle toujours une donnée personnelle ?

En pratique, oui : elle est traitée comme une DCP car elle peut permettre d'identifier une personne, notamment en la recoupant avec les données d'un fournisseur d'accès. La jurisprudence européenne a admis que même une adresse IP **dynamique** peut être personnelle lorsque l'organisme dispose de moyens légaux d'identification. À l'examen : répondre « oui, identification indirecte » et le justifier.

Q2. Quelle différence entre anonymisation et pseudonymisation ? Un hash est-il anonyme ?

L'**anonymisation** est irréversible : plus personne ne peut identifier la personne, et le RGPD ne s'applique plus. La **pseudonymisation** remplace les identifiants par un pseudonyme mais reste réversible (clé, table de correspondance, ou simple recoupement) : ce sont **toujours des DCP**. Un hash d'e-mail ou de numéro de téléphone est une pseudonymisation : il suffit de hacher une liste de candidats pour retrouver l'original. C'est une mesure de sécurité utile (art. 32), pas une sortie du RGPD.

Q3. Une adresse e-mail professionnelle est-elle une donnée personnelle ?

Oui si elle identifie une personne (`prenom.nom@entreprise.fr`). Le RGPD protège la **personne physique**, y compris dans son cadre professionnel. Une adresse générique (`contact@`) est beaucoup moins concernée. Les **personnes morales** (la société elle-même) ne sont pas protégées par le RGPD.

Q4. Le consentement est-il obligatoire pour tout traitement ?

Non. Le consentement n'est qu'**une** des six bases légales (art. 6). Un employeur qui traite les données de paie s'appuie sur le contrat et l'obligation légale ; une boutique qui livre une commande s'appuie sur l'exécution du contrat. Le consentement est surtout requis pour la prospection par certains canaux, les cookies non essentiels ou, avec la condition d'être **explicite**, pour certaines données sensibles. Attention : dans une relation de subordination (employeur/salarié), le consentement est rarement considéré comme « libre ».

Q5. Quelle différence concrète entre responsable de traitement et sous-traitant ?

Le **responsable** décide pourquoi (finalité) et comment (moyens essentiels) les données sont traitées. Le **sous-traitant** agit sur instruction, pour son compte (hébergeur, prestataire de paie, éditeur SaaS). Leur relation est encadrée par un **contrat** (art. 28). Exemple FitZone : FitZone est responsable de traitement ; l'éditeur de newsletter est sous-traitant. Le prestataire SISR qui intervient sur le serveur peut aussi être sous-traitant dès qu'il accède aux données.

Q6. L'organisme doit-il obligatoirement désigner un DPO ?

La désignation est **obligatoire** pour les autorités et organismes publics, pour les organismes dont l'activité de base exige un suivi régulier et systématique des personnes à grande échelle, et pour ceux qui traitent des données sensibles à grande échelle (art. 37). Pour les autres, elle est facultative mais recommandée ; on désigne alors souvent un **référent RGPD**.

Q7. Le registre des traitements est-il obligatoire pour une petite structure ?

En principe oui. L'article 30 prévoit une dérogation pour les organismes de moins de 250 salariés, mais elle **ne s'applique pas** si le traitement n'est pas occasionnel, présente un risque pour les personnes ou porte sur des données sensibles. Dans la pratique, la quasi-totalité des organismes doivent tenir un registre. FitZone (45 salariés, données de santé et biométrie) doit en tenir un.

B. Violations de données et sanctions

Q8. À partir de quand court le délai de 72 heures, et les week-ends comptent-ils ?

Le délai court à partir du moment où le responsable de traitement **a pris connaissance** de la violation (avec un degré raisonnable de certitude), et il **inclut les week-ends et jours fériés**. La notification peut être faite **par étapes** : une première information, complétée ensuite. Si elle dépasse 72 h, il faut en justifier les raisons. Le sous-traitant doit, lui, avertir le responsable « dans les meilleurs délais ».

Q9. Faut-il notifier toutes les violations de données ?

Non. La notification à la CNIL n'est pas nécessaire lorsque la violation n'est **pas susceptible d'engendrer un risque** pour les droits et libertés des personnes (art. 33). En revanche, **toute** violation doit être **documentée** dans un registre interne des violations. L'information des personnes concernées (art. 34) n'est exigée que si le risque est **élevé** (ex. fuite de données de santé ou bancaires non chiffrées).

Q10. Un ransomware est-il une violation de données si rien n'a été volé ?

Oui. Une violation couvre aussi la **perte de disponibilité** : des données chiffrées et inaccessibles sont une violation (atteinte à la disponibilité). Si les données ont aussi été copiées (double extorsion), il y a en plus atteinte à la confidentialité. La notification dépend ensuite du risque pour les personnes (ex. soins retardés, impossibilité d'exercer ses droits).

Q11. Les amendes de 10 M€ et 20 M€ sont-elles automatiques ?

Non. Ce sont des **plafonds**, pas des montants fixes. La CNIL tient compte de la gravité, de la durée, du caractère intentionnel, des mesures prises pour limiter le dommage, de la coopération et de la taille de l'organisme. Pour une entreprise, on retient le plafond **le plus élevé** entre le montant fixe et le pourcentage du chiffre d'affaires mondial. Beaucoup de sanctions concernent des PME avec des montants bien inférieurs aux plafonds.

Q12. Combien de temps conserver les images de vidéosurveillance ?

Les images de personnes identifiables sont des DCP. La CNIL recommande en règle générale une conservation de **quelques jours**, et qui ne devrait pas dépasser **un mois**. Les personnes doivent être informées (affichage), l'accès aux images doit être limité, et les caméras dans des lieux intimes (vestiaires, toilettes) sont en principe **disproportionnées**. « Jusqu'à saturation du disque » n'est pas une durée de conservation : c'est un manquement à la limitation de la conservation.

Q13. Pourquoi l'empreinte digitale pose-t-elle problème pour contrôler l'accès ?

C'est une donnée **biométrique** : sensible, et surtout **non révocable** (on ne change pas d'empreinte comme on change de mot de passe). Son usage est strictement encadré : la nécessité doit être justifiée, une **alternative** (badge) doit être proposée, le consentement explicite est requis dans une relation client, les gabarits doivent être chiffrés, et une **AIPD** est le plus souvent nécessaire.

Q14. Pourquoi ne faut-il pas conserver le certificat médical complet d'un abonné ?

Par le principe de **minimisation** : l'organisme a besoin de savoir que la personne est apte, pas de connaître son état de santé. En pratique, on conserve l'information utile (apte / inapte, date de validité) plutôt que la copie complète du document, qui est une donnée de santé donc sensible. Moins on conserve, moins la fuite potentielle est grave.

C. Analyse de risques

Q15. Menace, vulnérabilité, événement redouté, risque : comment les distinguer ?

La **menace** est la source (pirate, employé négligent, panne). La **vulnérabilité** est la faiblesse exploitable (mot de passe partagé, absence de sauvegarde). L'**événement redouté** est l'atteinte qu'on veut éviter (fuite des certificats). Le **risque** est l'ensemble pondéré par sa probabilité et sa gravité. Moyen mnémotechnique : *une menace exploite une vulnérabilité pour provoquer un événement redouté sur un actif*.

Q16. Comment rédiger correctement un événement redouté ?

Une formule simple : **[atteinte C / D / I / preuve] de [donnée ou actif] due à [menace] qui exploite [vulnérabilité], avec pour conséquence [impact]**. Exemple : « Atteinte à la confidentialité des certificats médicaux due à un employé ou un attaquant exploitant un dossier partagé ouvert à tous, avec usurpation d'identité et atteinte à la vie privée des abonnés. » Une phrase précise vaut mieux qu'un titre vague (« fuite de données »).

Q17. Sûreté ou sécurité : comment classer un incident ?

On regarde l'**intention**. Panne de disque, erreur de manipulation, incendie, orage : **sûreté**. Intrusion, ransomware, vol de données : **sécurité**. Un employé qui supprime un fichier par erreur relève de la sûreté ; s'il le fait par vengeance, c'est de la sécurité. Dans les deux cas, si des DCP sont détruites, perdues ou divulguées, c'est une **violation de données** au sens du RGPD.

Q18. Matrice 5 × 5 ou 4 × 4 : laquelle utiliser à l'examen ?

Celle que l'énoncé impose. Les deux suivent le même principe (**criticité = probabilité × gravité**). La matrice 5 × 5 est typique de la gestion de projet ; l'échelle à 4 niveaux (négligeable, limité, important, maximal) est celle d'EBIOS RM et de la CNIL. Si l'énoncé n'en donne pas, annoncer et définir vous-même l'échelle choisie, puis la respecter dans tout le document.

Q19. Comment fixe-t-on le seuil d'acceptabilité ?

Le seuil est une **décision de l'organisation** (direction, DPO, RSSI), pas une valeur universelle. Il dépend de l'appétence au risque, du secteur et des enjeux pour les personnes. Dans ce cours, on retient ≥ 10 sur 25 pour la matrice 5 × 5, d'après le schéma de référence. À l'examen : toujours indiquer le seuil retenu et justifier le choix.

Q20. Un risque très grave mais très peu probable peut-il être ignoré ?

Dans la gestion de projet classique, un risque « de gravité » (météorite, pandémie) est un risque avec lequel on vit. Mais en protection des données, **la gravité pour les personnes** prime : une fuite de données de santé ou biométriques, même peu probable, impose des mesures renforcées et souvent une AIPD. On ne peut donc écarter un tel risque que si sa gravité pour les personnes est réellement faible.

Q21. Quelle différence entre risque, problème et faute ?

Un **risque** est un événement futur possible. Un **problème** est un événement dommageable déjà réalisé. Une **faute** est une erreur connue et non corrigée. Exemples FitZone : « le serveur pourrait être chiffré » est un risque ; « le mot de passe admin est partagé et connu de tous » est un problème et une faute, à corriger immédiatement sans passer par la cotation.

Q22. Que signifie « accepter un risque » ? Peut-on tout accepter ?

Accepter, c'est décider, **par écrit** et en connaissance de cause, de conserver un risque résiduel sous le seuil. L'acceptation doit être documentée, validée par un responsable, et réexaminée. On ne peut pas accepter n'importe quoi : un risque intolérable (très probable et très grave), ou une non-conformité légale (ex. données sensibles sans base légale), doit être réduit, évité ou transféré.

Q23. L'AMDEC et la matrice probabilité × gravité sont-elles équivalentes ?

L'AMDEC ajoute un troisième facteur, l'**indéterminabilité** (probabilité de ne pas détecter l'incident à temps). Deux risques de même criticité P × G n'ont pas le même niveau d'urgence si l'un est détecté immédiatement et l'autre passe inaperçu pendant des mois. C'est l'argument en faveur de la journalisation et de la détection (2e année).

D. Méthode d'examen et lien avec le reste du programme

Q24. Comment aborder l'analyse d'un document technique (schéma, tableau de risques, extrait de logs) ?

Quatre temps : (1) **identifier** le type de document et le contexte ; (2) **repérer** les éléments critiques (données sensibles, accès, durées, flux) ; (3) **relever les incohérences** (ex. risque coté « faible » alors que la vulnérabilité est élevée, absence de durée de conservation) ; (4) **recommander** des mesures justifiées. Présenter en tableau : constat → risque → mesure → principe RGPD ou critère concerné.

Q25. Combien de mesures proposer et de quel type ?

Peu importe le nombre : ce sont la **pertinence** et la **justification** qui comptent. Viser 5 à 8 mesures prioritaires, mélangeant **techniques** (MFA, chiffrement, sauvegarde 3-2-1 hors ligne, journalisation, segmentation), **organisationnelles** (charte, habilitations, sensibilisation, contrats avec les sous-traitants, registre) et **physiques** (accès aux locaux, destruction sécurisée). Chaque mesure doit être reliée à un risque coté et à une couche de défense.

Q26. Prévention, protection, réparation : quelle différence ?

La **prévention** réduit la probabilité que le risque devienne un problème (MFA, formation, mises à jour). La **protection** réduit l'impact si le risque se réalise (chiffrement, segmentation, sauvegarde). La **réparation** prévoit comment réagir quand le problème est avéré (restauration, notification 72 h, communication). Un bon plan de prévention contient les deux volets, avec un **responsable** par risque.

Q27. Pourquoi 4 critères (preuve incluse) alors que beaucoup de cours parlent de CIA ?

Le triptyque **confidentialité – intégrité – disponibilité** est le socle. Le support de référence ajoute la **preuve** (non-répudiation), car prouver qui a fait quoi est indispensable pour enquêter, sanctionner et démontrer sa conformité (responsabilité, art. 5.2). À l'examen, suivre le vocabulaire de l'énoncé ; en cas de doute, traiter les trois critères classiques et mentionner la preuve en plus.

Q28. Comment ces deux séances préparent-elles la suite du programme ?

Séance 3 : les outils Kali (nmap, nikto) servent à **découvrir des données exposées**, ce qui repose sur la cartographie. Séances 4 à 6 : les **droits des personnes**, la notification de violation et la **collecte de preuves** reprennent la notion de preuve et de traçabilité. En 2e année, EBIOS RM approfondit la démarche (ateliers, scénarios), et la DMZ, les VLAN et le Zero Trust reprennent le schéma de défense en profondeur.

Q29. Que faut-il absolument savoir par cœur ?

(1) Définition de la DCP et liste des données sensibles ; (2) les **7 principes** et les **6 bases légales** ; (3) la définition d'une violation et le délai de **72 h** ; (4) les **4 critères** de sécurité et les 3 éléments de la preuve ; (5) la formule **C = P × G** et l'idée de seuil ; (6) les 5 étapes de la gestion des risques ; (7) l'article **32** (sécurité adaptée au risque) et l'article **35** (AIPD).

Note formateur

Les réponses juridiques sont données à titre pédagogique. Pour un cas réel, se reporter au texte du RGPD, aux lignes directrices du CEPD et aux publications de la CNIL en vigueur.